

PENTEST REPORT

Reconnaissance and Vulnerability Analysis

Target: 10.129.229.26
Generated: 05/06/2026 08:40 · NmapRAG Engine

2	8	4	3	0
Open Ports	Vulnerabilities	Critical	High	Sessions

Report Contents

1	Executive Summary
2	Confirmed Attack Vectors
3	Ports and Services
4	Web Fuzzing Findings (ffuf)
5	CVE Vulnerabilities — Full Detail
6	Execution Timing
7	Execution Log

1. Executive Summary

Attack Surface Summary

The attack surface is **HIGH** due to the presence of a Golang net/http server on port 55555, which may be a custom application with potential vulnerabilities. The server returns a 302 redirect to /web, indicating a possible web interface that could be exploited if misconfigured or vulnerable. Additionally, OpenSSH 8.2p1 is running on port 22, supporting both password and public key authentication, which increases the risk of brute-force or credential-based attacks.

Detected Services and Versions

- **TCP 22:** OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
 - **TCP 55555:** Golang net/http server
-

Key Findings

- A Golang net/http server is running on port 55555, which may be a custom application.
 - The server returns a 302 redirect to /web when a GET request is made, suggesting a potential web interface.
 - The server enforces a specific pattern for a 'basket name' in some requests, which could be a custom validation rule for a specific feature or API endpoint.
 - OpenSSH 8.2p1 supports both public key and password authentication methods.
 - No known backdoors or RCE vulnerabilities were explicitly identified in the provided data.
-

Recommended Next Steps

1. Investigate the Golang net/http server on port 55555:

- Use tools like `nuclei` or `gobuster` to scan for common vulnerabilities or misconfigurations in the web application.
- Example command:

```
gobuster dir -u http://10.129.229.26:55555 -w /usr/share/wordlists/dirb/common.txt
```

2. Check for known vulnerabilities in OpenSSH 8.2p1:

- Verify if the version is affected by any known vulnerabilities using CVE databases.
- Example command:

```
cve-search OpenSSH 8.2p1
```

3. Test for potential RCE or misconfigurations in the Golang server:

- Use Metasploit to test for known vulnerabilities in Golang-based applications.
- Example command:

```
msfconsole
use exploit/multi/http/golang_gin_rce
set RHOSTS 10.129.229.26
set LHOST <your_ip>
run
```

4. Assess the web interface at /web:

- Use `curl` or `wget` to inspect the content and behavior of the `/web` endpoint.
- Example command:

```
curl -v http://10.129.229.26:55555/web
```

5. Implement strong authentication and rate-limiting for SSH:

- Disable password authentication and enforce public key authentication.
- Use `fail2ban` or similar tools to prevent brute-force attacks.

2. Confirmed Attack Vectors

2 known vulnerabilities identified by automatic correlation of detected service versions against the exploit knowledge base. These vectors are **confirmed** by exact service version and do not depend on LLM analysis.

[HIGH] Golang net/http server vulnerability

CVE-2023-27163

Port: 55555 · **Service:** golang Golang net/http server

[CRITICAL] OpenSSH vulnerability

CVE-2003-0693

Port: 22 · **Service:** openssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)

3. Ports and Services Detected

2 open port(s) detected on target.

Port	Service	Version	Proto	Notes
22	OpenSSH	8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)	TCP	■ Sensitive service
55555	Golang	net/http server	TCP	

4. Web Fuzzing Findings (ffuf)

3 paths discovered via directory fuzzing. Findings are listed below with associated risk analysis.

Other discovered paths (3)

The following paths have no predefined risk pattern but should be reviewed manually for undocumented functionality.

- `http://10.129.229.26:55555/` [302] 27 bytes
- `http://10.129.229.26:55555/baskets` [401]
- `http://10.129.229.26:55555/web` [200] 8700 bytes

5. CVE Vulnerabilities — Full Detail

6 CVE(s) identified across exposed services (2 from NVD · 0 from knowledge base).

Severity	Count	Typical Impact
CRITICAL	3	Remote code execution, full system compromise
HIGH	2	Privilege escalation, unauthorised data access
MEDIUM	1	Denial of service, partial information disclosure

Port 22 — OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)

[CRITICAL] CVE-2003-0693

10.0

A "buffer management error" in `buffer_append_space` of `buffer.c` for OpenSSH before 3.7 may allow remote attackers to execute arbitrary code by causing an incorrect amount of memory to be freed and corrupting the heap, a different vulnerability than CVE-2003-0695.

Published	2003-09-22
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	NVD-CWE-Other

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

- lists.grok.org.uk
- lists.grok.org.uk
- lists.grok.org.uk
- NVD

[CRITICAL] CVE-2010-4478**9.8**

OpenSSH 5.6 and earlier, when J-PAKE is enabled, does not properly validate the public parameters in the J-PAKE protocol, which allows remote attackers to bypass the need for knowledge of the shared secret, and successfully authenticate, by sending crafted values in each round of the protocol, a related issue to CVE-2010-4252.

Published	2010-12-06
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Attack Vector	NETWORK
CWE	CWE-287, CWE-287

Exploitation context:

Remotely exploitable — no physical access or local presence required. Authentication failure: access possible without valid credentials. Authentication failure: access possible without valid credentials.

References:

kb.juniper.net
seb.dbzteam.org
openbsd.org
NVD

[CRITICAL] CVE-2008-3844**9.3**

Certain Red Hat Enterprise Linux (RHEL) 4 and 5 packages for OpenSSH, as signed in August 2008 using a legitimate Red Hat GPG key, contain an externally introduced modification (Trojan Horse) that allows the package authors to have an unknown impact. NOTE: since the malicious packages were not distributed from any official Red Hat sources, the scope of this issue is restricted to users who may have obtained these packages through unofficial distribution points. As of 20080827, no unofficial distributions of this software are known.

Published	2008-08-27
CVSS Vector	AV:N/AC:M/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	CWE-20

Exploitation context:

Remotely exploitable — no physical access or local presence required. RCE confirmed: search Exploit-DB or GitHub for PoC.

References:

secunia.com
secunia.com
securitytracker.com
NVD

[HIGH] CVE-2006-5051**8.1**

Signal handler race condition in OpenSSH before 4.4 allows remote attackers to cause a denial of service (crash), and possibly execute arbitrary code if GSSAPI authentication is enabled, via unspecified vectors that lead to a double-free.

Published	2006-09-27
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Attack Vector	NETWORK
CWE	CWE-415

Exploitation context:

Remotely exploitable — no physical access or local presence required. DoS: may disrupt the service.

References:

ftp.freebsd.org
patches.sgi.com
docs.info.apple.com
NVD

[HIGH] CVE-2015-5600**8.1**

The `kbdint_next_device` function in `auth2-chall.c` in `sshd` in OpenSSH through 6.9 does not properly restrict the processing of keyboard-interactive devices within a single connection, which makes it easier for remote attackers to conduct brute-force attacks or cause a denial of service (CPU consumption) via a long and duplicative list in the `ssh -oKbdInteractiveDevices` option, as demonstrated by a modified client that provides a different password for each pam element on this list.

Published	2015-08-03
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Attack Vector	NETWORK
CWE	CWE-264, CWE-400

Exploitation context:

Remotely exploitable — no physical access or local presence required. RCE confirmed: search Exploit-DB or GitHub for PoC. DoS: may disrupt the service.

References:

cvsweb.openbsd.org
cvsweb.openbsd.org
kb.juniper.net
NVD

Port 55555 — Golang net/http server

[MEDIUM] CVE-2023-27163**6.5**

request-baskets up to v1.2.1 was discovered to contain a Server-Side Request Forgery (SSRF) via the component `/api/baskets/{name}`. This vulnerability allows attackers to access network resources and sensitive information via a crafted API request.

Published	2023-03-31
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N
Attack Vector	NETWORK
CWE	CWE-918, CWE-918

Exploitation context:

Remotely exploitable — no physical access or local presence required. RCE confirmed: search Exploit-DB or GitHub for PoC.

References:

packetstormsecurity.com
packetstormsecurity.com
request-baskets.com
NVD

6. Execution Timing

Total scan duration: **13m 03s** (783.6s)

Phase	Duration	% of Total
Model warm-up	1m 42s	13.1%
Phase 0 — TCP Discovery	28s	3.6%
Phase 1 — Version Detection	52s	6.7%
Phase 2 — Adaptive NSE	4m 41s	36.0%
Phase 3 — Firewall Detection	5s	0.7%
Phase 4 — UDP Scan	25s	3.3%
Phase 5 — Web Fuzzing	49s	6.3%
Phase 6 — Metasploit	1m 30s	11.5%
Phase 7 — Searchsploit + Creds	1m 04s	8.2%
Total	13m 03s	100%

7. Execution Log

13 step(s) executed during reconnaissance.

✓ Step 1 — Full TCP SYN scan (all 65535 ports)

```
nmap -Pn -sS -p- --min-rate 1000 --max-retries 2 10.129.229.26
```

→ Found: 22 (ssh), 55555 (unknown)

✓ Step 2 — Version + OS detection on 22,55555

```
nmap -Pn -sV -O --version-intensity 5 -sC --script-timeout 60s -p 22,55555 -oX /home/marina/Desktop/pentestM/RAG/outputs/nmap_sV_10_129_229_26.xml 10.129.229.26
```

→ Found: 22 (OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)), 55555 (Golang net/http server)

→ Golang net/http server running on port 55555

→ OpenSSH 8.2p1 detected on port 22

→ Web application identified on port 55555: Request Baskets (from http-title)

✓ Step 3 — SSH Authentication Methods

```
nmap -Pn -sV --script ssh-auth-methods -p 22 10.129.229.26 --script-timeout 30s
```

→ Found: 22 (OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0))

→ SSH supports both publickey and password authentication methods

✓ Step 4 — Check for Shellshock Vulnerability

```
nmap -Pn -sV --script http-shellshock -p 55555 10.129.229.26 --script-timeout 30s
```

→ Found: 55555 (Golang net/http server)

✓ Step 5 — Enumerate Web Application on Port 55555

```
nmap -Pn -sV --script http-enum -p 55555 10.129.229.26 --script-timeout 30s
```

→ Found: 55555 (Golang net/http server)

✓ Step 6 — HTTP Methods Check

```
nmap -Pn -sV --script http-methods -p 55555 10.129.229.26 --script-timeout 30s
```

→ Found: 55555 (Golang net/http server)

→ The service at port 55555 is a Golang net/http server, which may be a custom application. The server returns a 302 redirect to '/web' when a GET request is made, suggesting a potential web interface.

→ The server enforces a specific pattern for a 'basket name' in some requests, which could be a custom validation rule for a specific feature or API endpoint.

✓ Step 7 — ACK scan — firewall detection

```
nmap -Pn -sA -p 22,55555 10.129.229.26
```

✓ Step 8 — UDP scan — top 100 ports by frequency

```
nmap -Pn -sU --top-ports 100 --open --max-retries 1 10.129.229.26
```

→ All 100 scanned UDP ports are in ignored states. No open UDP ports detected.

✓ Step 9 — UDP scan — exploit-focused service ports

```
nmap -Pn -sU -p 53,67,69,111,123,137,138,161,162,500,623,1434,1900,4500,5353,11211,17185 --open --max-retries 1 10.129.229.26
```

✓ Step 10 — ffuf — http://10.129.229.26:55555

```
ffuf -u http://10.129.229.26:55555/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780641379.json -of json -fc 404 -fs 75
```

→ [302] http://10.129.229.26:55555/

→ [200] http://10.129.229.26:55555/web

✓ Step 11 — ffuf vhosts — FUZZ.10.129.229.26

```
ffuf -u http://10.129.229.26:55555 -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -t 40 -H 'Host: FUZZ.10.129.229.26' -o /tmp/ffuf_vhost_55555_1780641423.json -of json -v -ac
```

✓ Step 12 — MSF exploitation phase

```
msfconsole (multiple modules)
```

✗ Step 12 — Searchsploit + credential phase

```
searchsploit / paramiko / ftplib
```